

• Static analysis: In this we analyse the file without executing it. It is more safe.

• Dynamic analysis: In this we analyse the file by executing it so we need to create a isolated environment to safe

Page No.	
Date:	

CAPA : THE BASICS

- CAPA stands for common analysis platform for artifacts. This is not a official full forms, its just for understanding.

It is a tool that tells what a program (especially malware) is capable of doing. It scans a file and matches patterns called rules. Its input can be .exe file, .dll file, memory dump, shellcode.

- Command to use capa?

capa.exe filename or capa filename

capa -h → Shows what other parameters we can use with capa

capa -v → Gives detailed result on malware capabilities

capa -vv → Gives very detailed result on malware capabilities

- Dissecting i.e analyzing the results after we run capa on a file:

i) The first block contains basic information about the file:

Its cryptographic algorithms such as the md5 and Sha1/256.

Analysis tells that ~~capa~~ how capa performed its analysis on the file.

Tells the OS for which the identified capabilities apply.

Arch tells us whether we are dealing with binary 32bit/64bit.

Path where the analyzed file was located.

ii) MITRE ATT&CK (Adversarial Tactics, Techniques and common knowledge): It is a global knowledge repository that tells how attackers attack system. It documents everything tactics (what attackers want) and techniques (what he does to achieve it).

CAPA uses this format for output of these things:

FORMATS

SAMPLE

ATT&CK TACTIC :: ATT&CK TECHNIQUE ::

DEFENSE EVASION :: OBFUSCATED

TECHNIQUE IDENTIFIER

FILES or Information :: T1027

ATT&CK Tactic :: ATT&CK TECHNIQUE ::

DEFENCE EVASION: OBFUSCA

ATT&CK SUB-TECHNIQUE :: TECHNIQUE IDENTIFIER

IED FILES or information ::

Sub-TECHNIQUE IDENTIFIER

INDICATOR REMOVAL FROM

TOOLS T1027,005

c) MAEC : Malware Attribute Enumeration and Characterization

It is a standard way to describe malware in a structured and detailed formats. It is like a detailed report or format of malware containing its behaviour, Actions, Techniques used, relationship between actions.

Most commonly used MAEC values by CAPA: Downloader and Launcher

MAEC value

Description

Launcher

Exhibits behaviour that triggers specific action similar to malware behaviour

Downloader

Exhibits behaviour wherein its download and executes other files, usually seen on more complex malware.

d) Malware Behaviour catalogue: MBC is a standard list of malware behaviours used to describe what malware does.

The content of MBC below can be represented in two formats:

Format

Objective :: Behaviour :: Method
[Identifier]

Sample

ANTI-STATIC ANALYSIS :: Executable code
obfuscation :: Argument obfuscation
[BOA32.020]

Objective :: Behaviour :: [Identifier]

Communication :: HTTP Communication
:: [C0002]

Objective : High level goals, Ex: Persistence, Data theft, execution

Behaviour : Actual action, Ex: File creation, Process injection,
Network communication

Methods : Techniques used : API calls, specific system tricks.

Microobjective : It is a very specific, low-level goal that malware is trying to achieve. These actions are not necessarily malicious and may serve various objectives.

NOTE: Example : Objective - Persistence
Behaviour - Auto start execution
Micro objective - Runs at system startup using regist

c) Namespace and capability : The content of this block is represented in the below format.

FORMAT

Capability (Rule-name) :: TLN (Top-level
namespace) / Namespace

SAMPLE

reference anti-VM strings
:: Anti-Analysis / Anti-VM
/ VM-detection

Namespace is a category or folder that groups similar capabilities together.

TLN (Top-level namespace) is the first category namespace path.

- A YAML (YAML) rule is a structured rule file used to describe patterns or behaviours that a tool should detect.

NOTE: Remember that the capability's name is also the rule's name with an additional dash (-) between space.

Ex: Capability name: reference base64 string

Rule: reference-base64-string.yml

- Capa Explorer, Web: It is a web-based tool to visually explore capa results.

It is used because we get boring terminal output when we scan capa so this tool helps us to view the results in a GUI (graphical user interface).

But this tool expects a ^{capa} json file as its input. So we need to save our ^{capa} results in a json the commands for it are:

```
Capa -j capa filename > result.json
```

Save results in result.json